Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 2.3 / COMPANION WORKBOOK

Authorization to Operate

Authorize and Monitor: the package, the decision, and continuous monitoring

Take the Body of Evidence for the Inside the Network system through the Authorize and Monitor steps of the Risk Management Framework (RMF) in NIST SP 800-37 Revision 2, with the matching tasks of the Joint Special Access Program (SAP) Implementation Guide (JSIG), 11 April 2016. Assemble the authorization package, brief the risk for the Authorizing Official (AO), record a fictional decision with its terms, conditions, and duration, and keep the authorization current through change, reporting, and disposal before the package capstone.

MATERIALS EDITION 2.0 / COURSE 2.3

Updated 15 October 2026 · sbd-rmf-authorization-to-operate

NAME _____ / DATE _____

Table of contents

Read each module alongside the interactive course. Use the record tables to write down what you actually produce — the workbook is your record, not the course.

Before you start

RMF steps, tasks, and outputs

10 Assemble the authorization package

11 Support the authorization decision

12 Monitor and maintain authorization

Authorization to Operate package capstone

Evidence starters

Knowledge check answers

Sources

Course review and sign-off

> **HOW TO USE IT** Each module page has the same shape: its RMF step with the NIST SP 800-37 Rev. 2 and JSIG tasks and outputs, three short lessons, a worked example, the practice output, and a record table. Fill the tables from your own records — never from the sample values.

© 2026 Secure By Design Team LLC.

Before you start

Take the Body of Evidence for the Inside the Network system through the Authorize and Monitor steps of the Risk Management Framework (RMF) in NIST SP 800-37 Revision 2, with the matching tasks of the Joint Special Access Program (SAP) Implementation Guide (JSIG), 11 April 2016. Assemble the authorization package, brief the risk for the Authorizing Official (AO), record a fictional decision with its terms, conditions, and duration, and keep the authorization current through change, reporting, and disposal before the package capstone.

Prerequisites

- ☐ Course 2.2's outputs: the as-implemented System Security Plan and traceability matrix, the evidence index, the Security Assessment Plan and Report, the updated Risk Assessment Report, and the Plan of Action and Milestones.
- ☐ Course 2.1's continuous monitoring strategy.
- ☐ Your Inside the Network build, or the supplied sample records.

What this course covers

- Assemble and submit an authorization package that meets JSIG Task 5-2 and NIST Task R-1.
- Brief the risk for the AO's determination and record a fictional authorization decision with its terms, conditions, and duration.
- Keep the authorization current through security impact analysis, ongoing assessment, status reporting, and disposal.

Practice artifacts in this course

- Authorization package manifest — Identify the exact records submitted for the AO's decision, what each one satisfies (JSIG Task 5-2, NIST Task R-1), and whether their scope and versions agree.
- Executive risk summary — Give the AO the system, the assessed posture, the significant risk, and the decision requested on one page: the package's executive summary and the basis of the briefing.
- Authorization decision document — Practice recording what an AO's decision contains: the decision, its terms and conditions, its duration, and what monitoring must report.
- Continuous monitoring strategy — Define what is monitored, how often, by whom, and what triggers action, so the authorization basis stays current. Written in Select (S-5; JSIG Task 2-3) and run in module 12.
- Security impact analysis — Decide what a proposed or actual change does to the security posture before it goes ahead: which controls and records it touches, what must be reassessed, and who must be told (NIST M-1, JSIG 6-1).

© 2026 Secure By Design Team LLC.

RMF steps, tasks, and outputs

Each module follows one Risk Management Framework (RMF) step in NIST SP 800-37 Revision 2 order, with the matching tasks and outputs of the Joint Special Access Program Implementation Guide (JSIG), 11 April 2016.

MODULE	RMF STEP	NIST	JSIG
10 Assemble the authorization package	Authorize	R-1	5-2
11 Support the authorization decision	Authorize	R-2–R-5	5-3–5-4
12 Monitor and maintain authorization	Monitor	M-1–M-7	6-1–6-7

TWO DOCUMENTS, ONE SEQUENCE NIST SP 800-37 Revision 2 has seven steps, starting with Prepare. The 2016 JSIG follows Revision 1's six steps, from Categorize to Monitor, with SP 800-53 Revision 4 and CNSSI 1253 (March 2014). Confirm whether your program directs the JSIG, its successor, or other guidance.

© 2026 Secure By Design Team LLC.

Assemble the authorization package

> **WHY THIS MATTERS** Assemble an authorization package whose plans, assessment results, and open risks agree, and submit it for the authorizing official's decision.

The RMF step

Who does the work The system owner (in the JSIG, the Information System Owner, ISO) assembles and submits the package; a common control provider does the same for the controls it provides. The Authorizing Official (AO) receives it and may direct additional evidence.

- NIST R-1 · Authorization package
- JSIG Task 5-2 · Assemble and submit the security authorization package to the AO

What this module produces

- An authorization package assembled and submitted to the AO (NIST R-1; JSIG output: Security Authorization Package)
- An executive summary of the system, the assessment results, and the remaining risk (NIST R-1)
- A versioned package manifest naming each component, its basis, owner, and review check
- A consistency review that reconciles scope, inventory, findings, and open actions across the SSP, SCTM, RAR, SAR, and POA&M

JSIG step outputs Security Authorization Package

> **WHERE THE JSIG AND NIST DIFFER** The JSIG's minimum package is the SSP (with the SCTM, continuous monitoring strategy, and RAR), the SAR, and the POA&M, plus any evidence the AO directs. NIST R-1 adds an executive summary and treats privacy plans and privacy assessment reports alongside the security ones.

Learn

10.1 Package contents in the JSIG and NIST Assemble what the decision needs.

In NIST SP 800-37 Revision 2, Task R-1, the system owner assembles the authorization package and submits it to the Authorizing Official (AO). It holds an executive summary, the security and privacy plans, the assessment reports, and the Plan of Action and Milestones (POA&M).

The Joint Special Access Program (SAP) Implementation Guide (JSIG) applies that NIST foundation to SAP systems; its public edition, 11 April 2016, is built on SP 800-53 Revision 4. Its Task 5-2 sets a minimum: the System Security Plan (SSP), with its Security Controls Traceability Matrix (SCTM), continuous monitoring strategy, and Risk Assessment Report (RAR); the Security Assessment Report (SAR); and the POA&M. The AO can direct more.

10.2 Consistency and readiness review Check that the documents agree.

Compare the boundary, inventory, selected controls, implementation statements, findings, and open actions across the SSP, SCTM, RAR, SAR, and POA&M. Resolve identifiers, status, dates, and scope that disagree.

© 2026 Secure By Design Team LLC.

Follow the risk as well: each significant SAR finding should reach the RAR, the POA&M or a proposed acceptance, and the executive summary. A package can be complete as a collection of files and still be unreliable.

10.3 Submission workflow Submit through the approved workflow.

Follow the authority's system of record, required reviews, signatures, and submission steps. In the Enterprise Mission Assurance Support Service (eMASS) or another tool, the records still need the same substance.

Submitting hands the package to the AO; it decides nothing. This course uses a generic record workflow, and no live government submission is part of the training.

Worked example: A package consistency review

1. **SSP —** Describes 21 named systems, two of them planned and not yet built (SBD-NESSUS01, SBD-EPO01), and 50 Windows workstations.
2. **SAR —** Reports testing on the network for 18 named systems and the workstation sample.
3. **Reconcile —** Nothing claims the planned servers' controls. SBD-ROOTCA01 is never on the network, so it is assessed during its key ceremonies: a stated limitation, not a missing test.
4. **Record —** Note each explanation in the manifest's review checks and the executive summary before submitting.

Build

Assemble the practice system's package: an executive summary, the SSP with its SCTM, continuous monitoring strategy, and RAR, the SAR, the POA&M, and a privacy applicability record. List each in a versioned manifest with its basis (JSIG 5-2 or NIST R-1), owner, and review check.

Practice artifacts Authorization package manifest; Executive risk summary (see Evidence starters)

Think it through

Reconcile control identifiers, asset counts, findings, dates, and status across the SSP, SCTM, RAR, SAR, and POA&M, and explain each difference you keep. Walk the package through a generic eMASS-style submission using training data.

Check your understanding

Your authority follows the JSIG. What must the authorization package contain at a minimum?

- A. The executive summary only; the AO requests the rest.
- B. The SSP and the latest scan report.
- C. The SSP (with its SCTM, continuous monitoring strategy, and RAR), the SAR, and the POA&M, plus any evidence the AO directs.

Your record

RECORD	YOUR OBSERVATION
Authorization package manifest — location and version	
Executive risk summary — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** The package has to agree with itself: 21 named systems and 50 workstations in the SSP, and an assessment that explains why the offline root CA is tested only during its key ceremonies.

[1] NIST SP 800-37 Revision 2

[5] DoDI 8510.01

[6] DoDM 5205.07

[7] DCSA Voice of Industry · September 2025

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Support the authorization decision

WHY THIS MATTERS Brief the risk the authorizing official must determine, propose a response to each significant risk, and record what an authorization decision contains.

The RMF step

Who does the work The AO, helped by a designated representative for everything but the decision itself, determines the risk and chooses the response; making and signing the decision stays with the AO. The system owner (JSIG: ISO) and the Security Control Assessor (SCA) brief the risk and answer questions.

- NIST R-2 · Risk analysis and determination
- NIST R-3 · Risk response
- NIST R-4 · Authorization decision
- NIST R-5 · Authorization reporting
- JSIG Task 5-3 · Determine the risk
- JSIG Task 5-4 · Determine whether the risk is acceptable (the authorization decision)

What this module produces

- A risk determination for operating the system, informed by the package and risk assessments (NIST R-2; JSIG 5-3)
- A response to each significant risk: mitigation tracked in the POA&M or set as conditions, acceptance, or avoidance (NIST R-3)
- An authorization decision document: ATO, IATT, or DATO, with terms and conditions and a duration (NIST R-4; JSIG 5-4)
- A report of the decision and any significant control deficiencies to the officials who oversee risk (NIST R-5)
- An executive risk summary and AO briefing that support the decision without making it

JSIG step outputs Authorization decision document

WHERE THE JSIG AND NIST DIFFER The JSIG's decisions are ATO, IATT, and DATO; NIST names authorization to operate, authorization to use, common control authorization, or a denial. NIST also makes risk response (R-3) and authorization reporting (R-5) tasks of their own; the JSIG covers the AO's work in Tasks 5-3 and 5-4.

Learn

11.1 Risk determination Support the AO's risk determination.

In NIST Task R-2, the AO analyzes the package and determines the risk of operating the system. In JSIG Task 5-3, risk assessments, formal or informal, inform the AO's final determination.

Your briefing supports that analysis: the mission, the assessed posture, significant findings and their consequences, limitations, and the recommendation the Security Control Assessor (SCA) made with the SAR. A request for more evidence is part of the process, not a setback.

© 2026 Secure By Design Team LLC.

11.2 Risk response Choose a response for each significant risk.

In NIST Task R-3, the AO chooses a response to the risk determined. Planned mitigation is tracked in the POA&M, and conditions on operation go into the decision. Accepted deficiencies stay documented in the assessment report and are watched for change. Avoiding a risk can mean limiting the operation.

A POA&M entry tracks work; it doesn't accept risk. JSIG Task 5-4 puts the explicit acceptance of risk with the AO, who decides whether the risk to organizational operations and assets, individuals, other organizations, or national security is acceptable.

11.3 The decision and its reporting Record the decision so people can act on it.

The authorization decision document records the decision, its terms and conditions, and its duration. JSIG decisions are an Authorization to Operate (ATO), an Interim Authorization to Test (IATT), for testing rather than operation, or a Denied Authorization to Operate (DATO). NIST Task R-4 names authorization to operate or to use, common control authorization, or a denial.

Duration is time-driven or ongoing, backed by robust continuous monitoring. Only the AO makes and signs the decision. NIST Task R-5 then reports it, with any significant control deficiencies, to the officials who oversee risk.

Worked example: From an open finding to a decision record

1. **Determine —** FND-001: SBD-MGMT01 is missing from verified audit collection, so privileged activity there could go unseen in Splunk review.
2. **Respond —** Mitigate through PM-001, and propose an interim condition: the Information System Security Officer (ISSO) reviews SBD-MGMT01's local Security log and records each review.
3. **Decide —** The reviewer, acting as AO, records an exercise decision: the type, terms and conditions tied to PM-001, and a duration.
4. **Report —** Monitoring reports PM-001's milestones and the interim reviews. A course score is not an ATO.

Build

Write the executive risk summary and a five-minute AO briefing for the practice system. Then complete a fictional decision record: the decision type, terms and conditions, duration, and what monitoring must report.

Practice artifacts Executive risk summary; Authorization decision document (see Evidence starters)

Think it through

Defend one unresolved finding and answer a request for more evidence. Propose a response (mitigate, accept, or avoid), and explain why the decision belongs to the AO and why a complete package or a passing score doesn't produce an ATO.

Check your understanding

The AO will allow operation while an open finding is fixed. What must the decision document record?

- A. The decision, the terms and conditions tied to that finding, and the duration.
- B. Only the POA&M due dates.
- C. Nothing more: the open POA&M entry already accepts the risk.

Your record

RECORD	YOUR OBSERVATION
Executive risk summary — location and version	
Authorization decision document — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** The Authorizing Official decides for the whole system, not one server at a time. The briefing explains what this network enables, the risk that remains, and the conditions and monitoring that would come with an authorization.

[1] NIST SP 800-37 Revision 2

[5] DoDI 8510.01

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Monitor and maintain authorization

WHY THIS MATTERS Keep the authorization true as the system changes: analyze each change, assess and report as the strategy requires, support ongoing authorization, and plan disposal.

The RMF step

Who does the work The system owner (JSIG: ISO), with the Information System Security Manager (ISSM) and the ISSO, analyzes changes, remediates, updates the package, reports status, and carries out disposal. The control assessor (JSIG: SCA) runs the ongoing assessments. The AO, or in the JSIG a designee, reviews the status and decides whether the risk is still acceptable.

- NIST M-1 · System and environment changes
- NIST M-2 · Ongoing assessments
- NIST M-3 · Ongoing risk response
- NIST M-4 · Authorization package updates
- NIST M-5 · Security and privacy reporting
- NIST M-6 · Ongoing authorization
- NIST M-7 · System disposal
- JSIG Task 6-1 · Determine the security impact of proposed or actual changes
- JSIG Task 6-2 · Assess a selected subset of controls under the AO-approved monitoring strategy
- JSIG Task 6-3 · Conduct remediation actions from monitoring, risk assessment, and open POA&M items
- JSIG Task 6-4 · Update the SSP, SAR, and POA&M
- JSIG Task 6-5 · Report the security status
- JSIG Task 6-6 · Review the reported status: is the risk still acceptable?
- JSIG Task 6-7 · Implement a decommissioning strategy

What this module produces

- A security impact analysis for each proposed or actual change (NIST M-1; JSIG 6-1)
- Ongoing assessment results under the approved monitoring strategy (NIST M-2; JSIG 6-2)
- Remediation and an updated SSP, SAR, and POA&M that keep the original information (NIST M-3, M-4; JSIG 6-3, 6-4)
- Security status reports to the AO, event-driven, time-driven, or both (NIST M-5; JSIG 6-5)
- An ongoing authorization review, with the authorization updated as appropriate (NIST M-6; JSIG 6-6)
- A decommissioning strategy carried out when the system is retired (NIST M-7; JSIG 6-7)

JSIG step outputs Periodic ConMon deliverables; Updated SSP, SAR, POA&M; Updated Security Authorization, as appropriate

WHERE THE JSIG AND NIST DIFFER The steps match task for task. The JSIG is more specific: a security impact analysis that notifies the SCA, updates that keep the original information for oversight and audit, and a

© 2026 Secure By Design Team LLC.

> decommissioning strategy that includes a decommission letter. NIST reports security and privacy posture together.

Learn

12.1 Changes and security impact analysis Analyze a change before it changes the risk.

NIST Task M-1 watches the system and its environment for changes that affect its security and privacy posture. JSIG Task 6-1 makes that a security impact analysis (SIA): determine the impact of a proposed or actual change, notify the SCA, and revise the package as required.

A new component, information flow, dependency, control provider, or threat can undercut the assessment the decision relied on. The size of a technical change doesn't tell you the size of its consequence.

12.2 Assessment, updates, and reporting Assess, respond, update, and report.

The continuous monitoring (ConMon) strategy the AO approved sets which controls are assessed, how often, and by whom; JSIG Task 6-2 assesses a selected subset (NIST M-2). Continuous doesn't mean testing every control constantly.

Results feed remediation and risk response (M-3, 6-3) and updates to the SSP, SAR, and POA&M that keep the original information needed for oversight and audit (M-4, 6-4). The system owner reports status to the AO, event-driven, time-driven, or both (M-5, 6-5).

12.3 Ongoing authorization and disposal Keep the decision current until the system retires.

In NIST Task M-6 and JSIG Task 6-6, the AO (or, in the JSIG, a designee) reviews the reported status to decide whether the risk is still acceptable. If not, the AO decides what follows: new conditions, reassessment, or a new decision.

Disposal closes the loop (M-7, 6-7). The JSIG's decommissioning strategy covers media sanitization, a records retention plan the AO approves, inventory updates, notifications, a review of inherited relationships, and a decommission letter.

Worked example: A change goes through security impact analysis

1. **Change —** A second licensed application is proposed for SBD-APPS01, adding its vendor licensing port to rule F12 for the VLAN 80 workstations.
2. **Impact —** New software and a changed flow: configuration (CM-6, a SCAP Compliance Checker rescan), the vendor's update path (SI-2), its events (AU-2, AU-12), and the course 1.19 recovery set (CP-9).
3. **Decide —** Notify the SCA, reassess before go-live, and give the SIA to the AO or designee, who decides whether it fits the current authorization.
4. **Update —** Update the inventory, SSP, SCTM, rule register, and evidence index, report the change in the next status report, and keep the prior versions.

Build

Run one cycle of the continuous monitoring strategy course 2.1 drafted: the controls assessed, owners, evidence, reporting dates, and escalation triggers. Write a security impact analysis for one proposed change and a status report for the AO.

Practice artifacts Continuous monitoring strategy; Security impact analysis (see Evidence starters)

Think it through

Process a new licensed application on SBD-APPS01 (rule F12), a missed update in one of SBD-WSUS01's rings, and a changed common control such as the server room's badge access: what is reassessed, which records change, what the status report says, and when the AO is engaged. Then list the disposal steps if SBD-WEB01's service were retired, including what depends on it.

Check your understanding

A proposed change adds a port to a documented information flow. What comes first?

- A. Make the change; the current authorization covers future services.
- B. A security impact analysis: identify the affected controls and records, notify the SCA, and follow the required review.
- C. Nothing until the next reauthorization.

Your record

RECORD	YOUR OBSERVATION
Continuous monitoring strategy — location and version	
Security impact analysis — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** Monitoring keeps the package true: Splunk review and alerts, updates through SBD-WSUS01 and SBD-REPO01, and the inventory on SBD-MGMT01. A missed update goes to remediation and the status report; a new component starts a security impact analysis.

[1] NIST SP 800-37 Revision 2

[2] NIST SP 800-53 Revision 5

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

COURSE 2.3 / CAPSTONE / ABOUT 4 HOURS

Authorization to Operate package capstone

Assemble and defend the fictional enclave's authorization package. Show where the evidence supports a conclusion, where it does not, and what happens next.

Your submission

1. Authorization package manifest covering the JSIG Task 5-2 minimum and the NIST Task R-1 executive summary, with the scope, registration, and categorization records the package rests on.
2. SSP excerpt with its SCTM, continuous monitoring strategy, and RAR, covering the selected practice objectives.
3. Evidence index, Security Assessment Plan, and SAR excerpt with supported conclusions and visible limitations, including RA-5 scanning coverage.
4. At least two justified findings with POA&M entries and one remediation retest record, with any risk response (RA-7) presented for the AO's acceptance decision (CA-6).
5. Executive risk summary, five-minute AO briefing, a fictional authorization decision record (type, terms and conditions, duration), and one security impact analysis with a status report.

Nine controls, one coherent story

AC-2 · AU-2 · AU-3 · AU-6 · AU-12 · CM-6 · RA-5 · SI-2 · CP-9

Record the exact adopted requirements, parameters, and assessment objectives. This selection is a teaching subset; the actual system baseline follows its governing authority.

Use the logging trail in the Body of Evidence as the model: FND-001, SBD-MGMT01 missing from verified audit collection. Add a second finding from the rest of the scope. RA-5 is a good candidate: the SCAP Compliance Checker and Security Technical Implementation Guide (STIG) results cover configuration, but the network has no credentialed vulnerability scanning, so record that as a gap or limitation, never as a passed test. CM-6, SI-2 (SBD-WSUS01 and SBD-REPO01), and CP-9 (the course 1.19 restore record) offer others. Only the AO can accept risk (CA-6).

Scoring rubric

CRITERION	POINTS	WHAT THE REVIEWER LOOKS FOR
Package completeness and consistency	20	The manifest covers the JSIG 5-2 minimum and the NIST R-1 executive summary; scope, inventory, identifiers, and versions agree.
Traceability	25	Each selected objective links to implementation, evidence, and a conclusion or explicit gap.

CRITERION	POINTS	WHAT THE REVIEWER LOOKS FOR
Assessment quality	20	Methods and observations support conclusions; limitations, including RA-5 scanning coverage, stay visible.
Risk determination and response	20	Risk relates to mission impact; each significant risk has a proposed response, and POA&M actions have owners, dates, and verification criteria.
Decision record and monitoring	15	The briefing is clear; the decision record has a type, terms and conditions, and a duration; the change is analyzed and reported through the right records.

Completion threshold: 80 of 100 points. Revisions are required for unsupported successful assessment claims, inconsistent boundaries, or a claim that the learner granted a real ATO. Course completion is a training outcome; only the AO issues an authorization decision.

The review sequence

- 01 / ASSEMBLE — Reconcile the package: Check the JSIG 5-2 minimum and the NIST R-1 contents, then identifiers, scope, dates, versions, findings, and open actions.
- 02 / DETERMINE — Brief the risk: Explain mission need, significant results, limitations, and the response you propose for each significant risk.
- 03 / DECIDE — Record the decision: The reviewer, acting as AO, questions the evidence and records a fictional ATO, IATT, or DATO with terms, conditions, and a duration.
- 04 / MONITOR — Process the change: Run a security impact analysis, update the affected records, and send the status report the decision asks for.

Reviewer challenges

The SAR has no credentialed vulnerability scan results. Can RA-5 be marked satisfied?

The AO wants operation to start before FND-001 is fixed. What do you bring?

A new service crosses the documented boundary. What must be reviewed?

Evidence starters

Blank starters for the practice artifacts this course produces. Fill them from your own system. The interactive course shows a completed fictional example of each, and the training materials download includes each one as Markdown (and CSV for tables).

Authorization package manifest

Versioned package assembly Owner: System owner and package coordinator. Identify the exact records submitted for the AO's decision, what each one satisfies (JSIG Task 5-2, NIST Task R-1), and whether their scope and versions agree.

PACKAGE COMPONENT	BASIS	IDENTIFIER / VERSION	OWNER	REVIEW CHECK
[Required component]	[JSIG 5-2 / NIST R-1 / AO direction]	[Document ID / version / date]	[Responsible role]	[Required review / status]

The JSIG sets a minimum and the AO can direct more; the applicable authority sets the format and submission path. This manifest does not establish submission or approval.

Executive risk summary

Package executive summary and AO briefing Owner: System owner with risk stakeholders. Give the AO the system, the assessed posture, the significant risk, and the decision requested on one page: the package's executive summary and the basis of the briefing.

FIELD	YOUR ENTRY
System and mission — What the system enables, its boundary and categorization, the authority, and the package version under review.	
Assessment result — Significant supported results, limitations, and the assessor's recommendation, quoted from the SAR.	
Risk to the mission — Consequences, likelihood, uncertainty, existing safeguards, and the significant open findings, consistent with the RAR.	

© 2026 Secure By Design Team LLC.

FIELD	YOUR ENTRY
Proposed response — For each significant risk: mitigate (POA&M actions, conditions), accept, or avoid, with owners and alternatives.	
Decision requested — The decision requested (ATO, IATT, or DATO), the proposed duration, and who is authorized to decide.	

The summary informs the decision; it doesn't make it. Keep recommendations separate from the AO's recorded decision and its conditions.

Authorization decision document

Fictional decision exercise Owner: Authorizing official (played by the reviewer). Practice recording what an AO's decision contains: the decision, its terms and conditions, its duration, and what monitoring must report.

FIELD	YOUR ENTRY
System and scope — System name, boundary, and the package version the AO reviewed.	
Decision — ATO, IATT, or DATO (JSIG); NIST also names authorization to use, common control authorization, and denial. Who decided, and when.	
Terms and conditions — What must be done, maintained, or limited for the decision to stand, and who is responsible.	
Duration — Time-driven (an end date) or ongoing authorization backed by robust continuous monitoring, and the events that trigger an earlier review.	
Monitoring and reporting — What the system owner reports, when (event-driven, time-driven, or both), and to whom.	

FIELD	YOUR ENTRY
Authority and signature — Who signed, under which authority, and what the record is not.	

Exercise material only. A real authorization decision document is issued and signed by the appointed AO under the governing authority; nothing in this course grants an ATO, IATT, or DATO.

Continuous monitoring strategy

Maintain the authorization basis Owner: System owner (ISO) with control owners; approved by the Authorizing Official (AO). Define what is monitored, how often, by whom, and what triggers action, so the authorization basis stays current. Written in Select (S-5; JSIG Task 2-3) and run in module 12.

ACTIVITY	OWNER	FREQUENCY / TRIGGER	EVIDENCE AND ESCALATION
[Monitoring activity and the NIST and JSIG task it serves]	[Role]	[Frequency or trigger approved in the strategy]	[Record produced / threshold / action]

Frequencies and thresholds are dependent on your environment and set by the applicable direction and system risk; this example doesn't prescribe universal intervals. Module 12 runs the strategy and records each security impact analysis.

Security impact analysis

Change impact record Owner: System owner with the ISSM and ISSO. Decide what a proposed or actual change does to the security posture before it goes ahead: which controls and records it touches, what must be reassessed, and who must be told (NIST M-1, JSIG 6-1).

FIELD	YOUR ENTRY
Change — Change ID, what changes and why, requester, proposed date, affected components and information flows.	
Security impact — Affected controls, implementations, and evidence, and the effect on each: better, worse, or unknown.	

FIELD	YOUR ENTRY
Determination — Significant or not, and why; what must be reassessed; whether the boundary or categorization changes.	
Notifications and approvals — Who is told or must approve before the change: SCA, ISSM, change board, AO or designee.	
Records to update — Which package records change, who updates them, and which versions are kept.	
Outcome — Approved, deferred, or rejected; the reassessment result; date closed; the status report that carried it.	

The authority’s change process decides who approves a change and when the AO must be engaged. The example is a fictional change to the practice system.

Knowledge check answers

10 Your authority follows the JSIG. What must the authorization package contain at a minimum?

C. The SSP (with its SCTM, continuous monitoring strategy, and RAR), the SAR, and the POA&M, plus any evidence the AO directs. That is the JSIG Task 5-2 minimum. NIST Task R-1 adds an executive summary and puts privacy plans and assessment reports alongside the security ones.

11 The AO will allow operation while an open finding is fixed. What must the decision document record?

A. The decision, the terms and conditions tied to that finding, and the duration. The decision document carries the decision, its terms and conditions, and its duration. A POA&M tracks corrective work; accepting the risk is the AO's decision.

12 A proposed change adds a port to a documented information flow. What comes first?

B. A security impact analysis: identify the affected controls and records, notify the SCA, and follow the required review. NIST Task M-1 and JSIG Task 6-1 evaluate a change against the assessed and authorized scope before it quietly changes the risk.

Reviewer challenge guidance

The SAR has no credentialed vulnerability scan results. Can RA-5 be marked satisfied? No. SCAP Compliance Checker and STIG results show configuration compliance, not vulnerability scanning coverage. Record the gap as a limitation or finding, carry it into the RAR and the executive summary, and let the AO weigh it. Plan its assessment for when a credentialed scanning capability exists, and bring that capability in through a security impact analysis.

The AO wants operation to start before FND-001 is fixed. What do you bring? The risk in mission terms, the safeguards already in place, PM-001's milestones and verification, and proposed terms and conditions, such as a recorded interim review of SBD-MGMT01's local Security log. Present them as proposals: the AO decides whether to accept the risk with conditions, wait, or deny. An IATT isn't the answer; it covers testing, not operation. Record the outcome in the decision record, not in the POA&M.

A new service crosses the documented boundary. What must be reviewed? Run a security impact analysis: identify the new information flow, owner, data, dependencies, and protection requirements. Revisit the boundary and categorization assumptions, determine the affected controls, notify the SCA, and update the architecture, SSP, evidence, assessment, and risk records. The AO or designee decides whether the change still fits the current authorization.

© 2026 Secure By Design Team LLC.

Sources

Choose the applicable authority and record the adopted versions before using a template. Module reference numbers correspond to these documents.

[1] NIST SP 800-37 Revision 2

RMF lifecycle, tasks and outputs, authorization package, roles, and monitoring. See Chapter 3 and Appendix E.

[2] NIST SP 800-53 Revision 5

Security and privacy control catalog. Record the release adopted by the governing authority.

[3] NIST SP 800-53A Revision 5

Control assessment procedures and examine, interview, and test methods.

[4] NIST SP 800-53B

Control baselines, tailoring, and overlays. Apply the appropriate system context.

[5] DoDI 8510.01

Risk Management Framework for DoD Systems, July 19, 2022.

[6] DoDM 5205.07

Special Access Program Security Manual, January 17, 2025.

[7] DCSA Voice of Industry · September 2025

DCSA newsletter for cleared industry on the DAAG transition. Confirm the current guide, version, and effective date with DCSA.

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

The six RMF steps, tasks, and outputs for Special Access Program (SAP) systems, built on NIST SP 800-37 Revision 1, SP 800-53 Revision 4, and CNSSI 1253 (March 2014). Confirm whether your program directs it or a successor.

© 2026 Secure By Design Team LLC.

Course review and sign-off

Before moving on, confirm each module left its outputs behind — and that what remains open is written down.

Module completion

MODULE	OUTPUTS FILED	DATE
10 Assemble the authorization package	☐ yes	
11 Support the authorization decision	☐ yes	
12 Monitor and maintain authorization	☐ yes	
Capstone Authorization to Operate package	☐ yes	

Open items carried forward

Next in the learning path

That completes the Network Authorization path. Keep the package current through the monitoring strategy; only the authorizing official makes an authorization decision.

> **KEEP IT HONEST** Course completion records learning activity. It is not a system authorization, an assessment result, or an approval by any authorizing official. Exercise records are fictional.

© 2026 Secure By Design Team LLC.